API Security Risk Analysis Report

Prepared by: Suroor Muhammed Shafi

Executive Summary

This report presents the findings of an API Security Risk Analysis conducted on a public test API. The assessment was carried out using safe, read-only testing methods to identify common security weaknesses without causing any harm to the system.

The analysis revealed several key security concerns, including the absence of authentication mechanisms, exposure of user-related data such as email and address, lack of rate limiting, and basic error handling practices. These vulnerabilities, although identified in a test environment, reflect real-world risks that can affect modern applications relying on APIs.

If such issues exist in production systems, they could allow unauthorized users to access sensitive data, abuse system resources, or compromise user privacy. Therefore, it is essential for organizations to implement proper security controls such as authentication, data protection, and request limiting.

This report provides a clear explanation of the identified risks along with practical recommendations to improve API security and ensure safe and reliable system operations.

Introduction

In modern digital environments, Application Programming Interfaces (APIs) play a vital role in enabling communication between different systems, applications, and services. APIs are widely used in mobile applications, web platforms, cloud services, and third-party integrations, making them a critical component of today's technology infrastructure.

However, due to their direct exposure to external users and systems, APIs are also a common target for security threats. Poorly secured APIs can lead to serious risks such as unauthorized data access, data leakage, and system abuse. As a result, conducting regular API security assessments is essential for identifying vulnerabilities and ensuring secure operations.

This report focuses on analyzing a public API using safe and ethical testing methods. The objective is to identify common security risks, evaluate their potential impact in a business context, and provide clear, practical recommendations to improve security.

The findings of this assessment aim to reflect real-world scenarios and highlight the importance of implementing strong security practices in API development and management.

Scope & Ethics

Scope:

- Public API endpoints only
- Read-only testing (GET requests)
- Response and header inspection

Ethics:

- No exploitation attempts
- No brute-force or DoS testing
- No modification of data

Tools & Methodology

Tools Used:

- Postman
- Browser DevTools

Methodology:

1. Sent API requests using Postman
2. Observed responses and headers
3. Tested different endpoints
4. Analyzed security risks based on findings

API Overview

The API used in this assessment is **JSONPlaceholder**, a public test API designed for learning and testing. It provides sample data such as user details through RESTful endpoints in JSON format.

The API is publicly accessible and does not require authentication, making it suitable for analyzing common security risks. Key endpoints were tested to observe system behavior and identify potential vulnerabilities.

Endpoints Tested:

- /users
- /users/1
- /users/999

Response Type: JSON

Risk Classification

High: Critical issues affecting security and data access

Medium: Issues that can be exploited under certain conditions

Low: Minor issues with limited impact

Vulnerability Findings

1. No Authentication Required

- **Issue:** API allows access without authentication
- **Impact:** Anyone can access data
- **Risk Level:** High
- **Recommendation:** Implement API authentication (API keys, OAuth tokens)

2. Sensitive Data Exposure

- **Issue:** API exposes user data such as email, phone, and address
- **Impact:** Risk of privacy violations and misuse
- **Risk Level:** Medium
- **Recommendation:** Limit sensitive data exposure

3. No Rate Limiting

- **Issue:** API allows unlimited requests
- **Impact:** Can lead to abuse or service overload
- **Risk Level:** Medium
- **Recommendation:** Implement rate limiting

4. Improper Error Handling

- **Issue:** API returns simple responses for invalid requests
- **Impact:** May reveal behavior of the system
- **Risk Level:** Low
- **Recommendation:** Use standardized error responses

Risk Table

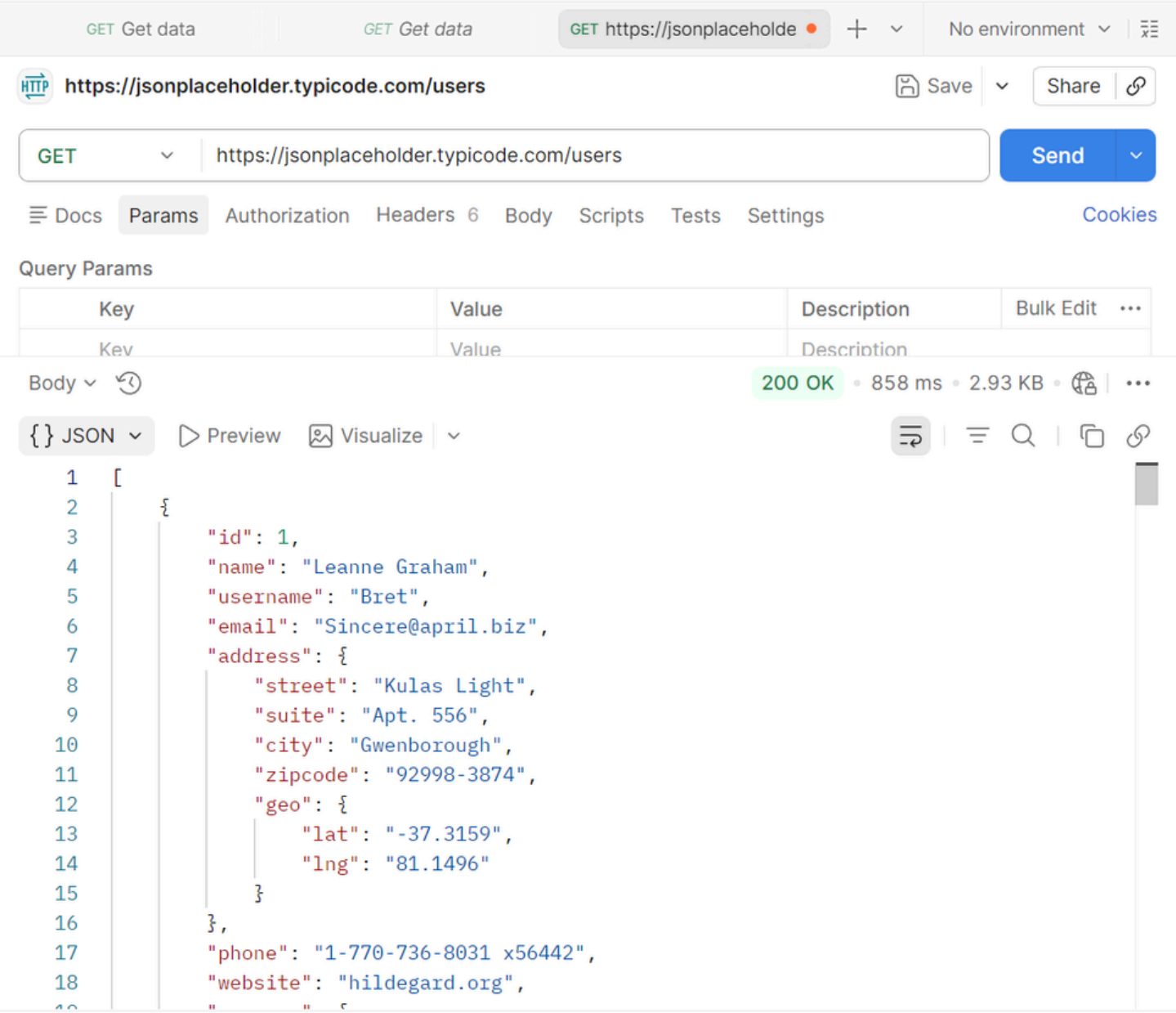
Risk Level	Issue	Recommendation
High	No Authentication	Implement authentication
Medium	Data Exposure	Limit sensitive data
Medium	No Rate Limiting	Add request limits
Low	Error Handling	Use generic errors

Evidence

The following section provides visual evidence collected during the API security assessment. The screenshots demonstrate the responses received from the API, highlighting key observations such as data exposure and system behavior under different request conditions.

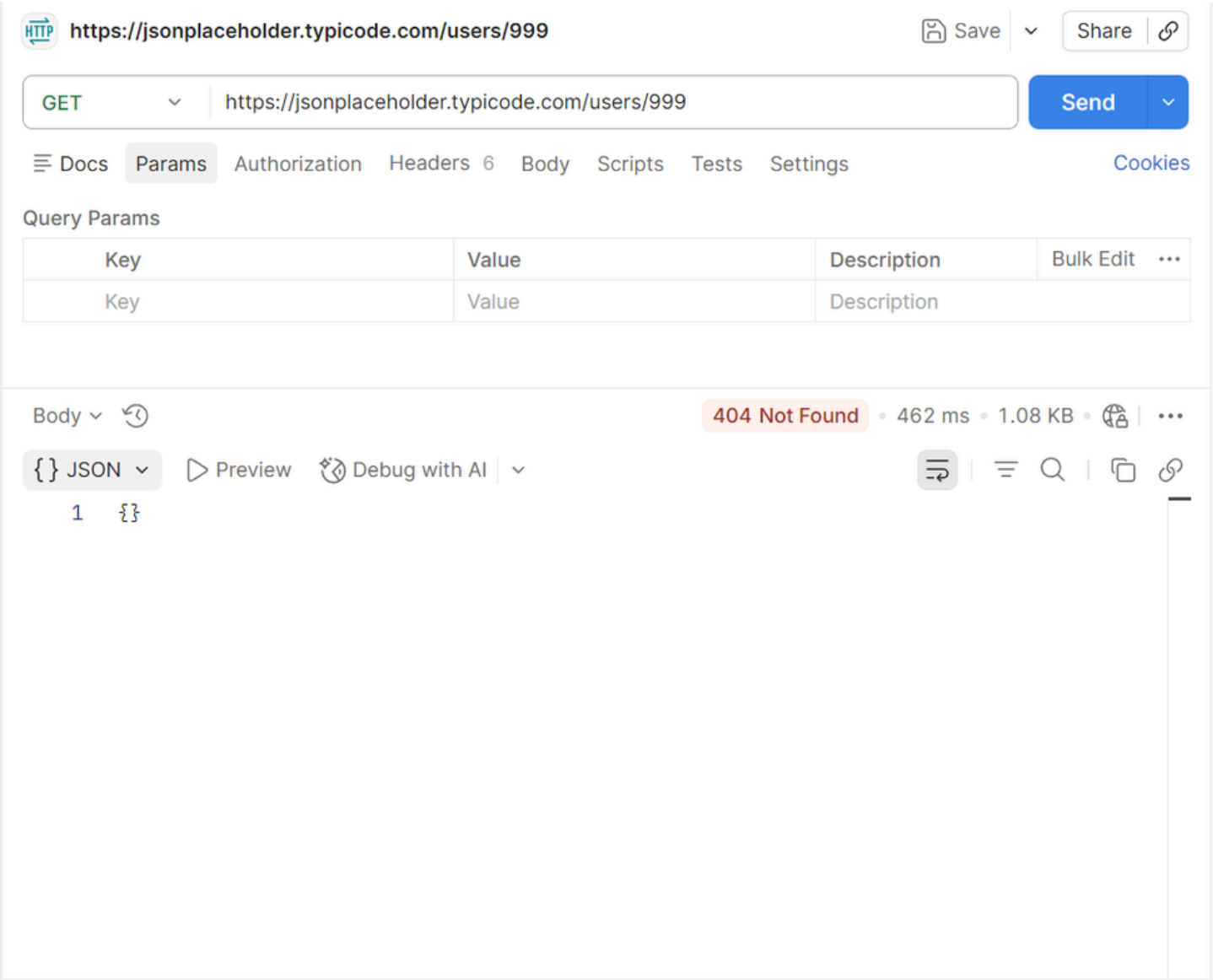
These visuals support the findings identified in this report and provide proof of the analysis conducted using safe and read-only testing methods.

Figure 1:



API response showing user data retrieved using Postman.

Figure 2



API response for an invalid request demonstrating error handling.

Conclusion & Recommendations

The API security assessment identified several important risks that could impact the confidentiality, integrity, and availability of data if present in a real-world system. The most critical issue observed was the absence of authentication, which allows unrestricted access to API endpoints. In addition, the exposure of user-related data such as email addresses, phone numbers, and location details highlights potential privacy concerns.

The lack of rate limiting also increases the risk of abuse, where attackers could send excessive requests to overload the system. Furthermore, basic error handling responses indicate that the API does not fully control how system behavior is revealed to users.

To improve security, it is strongly recommended that organizations implement proper authentication mechanisms such as API keys or OAuth tokens to restrict access. Sensitive data should be minimized or masked to protect user privacy. Additionally, rate limiting should be applied to control the number of requests and prevent misuse.

Overall, applying these security measures will significantly reduce risks and help ensure that APIs remain secure, reliable, and resilient against potential threats.

Limitations

This assessment was conducted using publicly available API endpoints and limited to read-only testing methods. No authentication-based testing or advanced security techniques were performed, as the scope strictly followed ethical and non-intrusive guidelines.

Additionally, the API used in this assessment is a demo environment, which may not fully represent real-world production systems. As a result, certain vulnerabilities may not be present or may behave differently in a live environment.

Due to these constraints, it is possible that additional security risks exist that were not identified during this assessment. A more comprehensive evaluation, including authenticated testing and penetration testing, would be required for a complete security analysis.

Future Recommendations

To further enhance API security, organizations should adopt a proactive and continuous approach to security management. Regular API security assessments and audits should be conducted to identify and address new vulnerabilities as systems evolve.

Implementing an API gateway can help enforce security policies such as authentication, rate limiting, and monitoring. Encryption techniques, including HTTPS and secure token handling, should be used to protect data during transmission.

In addition, organizations should invest in secure coding practices and provide training for developers to ensure that security is integrated during the development phase. Monitoring tools and logging mechanisms should also be implemented to detect suspicious activities and respond to potential threats in real time.

By following these practices, organizations can build secure APIs that support safe and efficient digital operations.